AEGIS BANK

API Development Standards

Enterprise AI Decision & Knowledge Platform for Modern Banking

---

Document Information

Field	Details
Document Title	API Development Standards
Document ID	**AB-IT-001**
Department	Information Technology & Engineering
Version	v1.2
Last Updated	July 24, 2026
Document Owner	Chief Technology Officer (CTO)
Classification	Internal
Review Date	July 24, 2027
Approved By	**Sami Khan – Chief Executive Officer (CEO)**

Confidentiality Notice

This document defines the technical standards, security requirements, and development practices for designing, building, testing, and maintaining APIs at Aegis Bank.

All engineering teams must follow these standards to ensure secure, scalable, reliable, and compliant banking systems.

Unauthorized modification or distribution of this document is prohibited.

Table of Contents

1. Purpose

2. Scope
3. API Development Principles
4. API Architecture Standards
5. API Design Guidelines
6. Authentication & Authorization
7. API Security Requirements
8. Data Validation Standards
9. Error Handling Standards
10. API Documentation Requirements
11. Version Management
12. Testing Requirements
13. Performance Standards
14. Logging & Monitoring
15. AI System API Standards
16. Deployment Requirements
17. Practical Examples
18. FAQs
19. Revision History
20. Document Approval

---

1. Purpose

The purpose of this document is to establish standardized practices for developing secure and reliable APIs at Aegis Bank.

These standards ensure:

- Consistent API development.
- Secure communication.

- Reliable banking services.
- Better system integration.
- Regulatory compliance.

---

2. Scope

This policy applies to:

- Backend developers.
- Software engineers.
- DevOps teams.
- API architects.
- Security engineers.
- External development partners.

It covers APIs used by:

- Core Banking Systems.
- Mobile Banking Applications.
- Internet Banking.
- Payment Systems.
- AI Services.
- Internal Enterprise Applications.

---

3. API Development Principles

Aegis Bank follows these API development principles:

Security First

Security must be considered during every development stage.

Reliability

APIs must provide stable and predictable behavior.

Scalability

API architecture must support future growth.

Maintainability

Code must follow clean architecture practices.

Documentation

Every API must have complete technical documentation.

---

4. API Architecture Standards

Aegis Bank follows modern API architecture patterns.

Supported architectures:

- REST APIs.
- Microservices APIs.
- Internal Service APIs.
- AI Service APIs.

REST API Guidelines

APIs should follow:

- Standard HTTP methods.
- JSON-based communication.
- Clear resource naming.
- Stateless communication.

Example:

Correct:

GET /customers/{customerId}

Incorrect:

GET /getCustomerInformation123

---

5. API Design Guidelines

API endpoints must be:

- Simple.
- Predictable.
- Consistent.

HTTP Methods

Method	Purpose
GET	Retrieve information
POST	Create new resources
PUT	Update resources
DELETE	Remove resources

Naming Standards

Use:

- Lowercase names.
- Plural resources.
- Meaningful paths.

Example:

/api/v1/accounts

/api/v1/transactions

/api/v1/customers

---

6. Authentication & Authorization

All banking APIs must implement secure authentication.

Approved methods:

- OAuth 2.0.
- JWT Authentication.
- API Keys for internal services.
- Multi-Factor Authentication.

Role-Based Access Control (RBAC)

API permissions must follow user roles.

Example:

Role	Permission
Customer	View own account
Employee	Access approved customer data
Admin	Manage system settings

---

7. API Security Requirements

All APIs must implement:

Encryption

Communication must use:

- HTTPS.
- TLS encryption.

Input Protection

APIs must prevent:

- SQL Injection.
- Cross-Site Scripting.
- Malicious payloads.

Rate Limiting

APIs must limit excessive requests.

Purpose:

- Prevent abuse.
- Reduce attacks.
- Maintain performance.

Security Testing

APIs must undergo:

- Vulnerability testing.
- Penetration testing.
- Security review.

---

8. Data Validation Standards

All incoming API data must be validated.

Validation includes:

- Required fields.

- Data types.
- Format checking.
- Business rules.

Example:

Loan API Request:

Required:

- Customer ID.
- Income information.
- Loan amount.

Invalid requests must be rejected.

---

9. Error Handling Standards

APIs must return clear error responses.

Example:

{

"status": "error",

"code": "AUTH_001",

"message": "Unauthorized access"

}

Common HTTP Codes:

Code	Meaning
200	Successful request
400	Invalid request

Code	Meaning
401	Unauthorized
403	Forbidden
404	Resource not found
500	Server error

---

10. API Documentation Requirements

Every API must include:

- Purpose.
- Endpoint details.
- Request format.
- Response format.
- Authentication method.
- Error codes.

Approved documentation tools:

- OpenAPI Specification.
- Swagger Documentation.

---

11. API Version Management

All APIs must support version control.

Example:

/api/v1/customers

/api/v2/customers

Versioning prevents service disruption.

---

12. API Testing Requirements

Before production release, APIs must pass:

Unit Testing

Tests individual functions.

Integration Testing

Tests system communication.

Security Testing

Checks vulnerabilities.

Performance Testing

Measures:

- Response time.
- Request handling.
- System capacity.

---

13. Performance Standards

APIs should maintain:

- Fast response times.
- High availability.
- Efficient resource usage.

Performance monitoring includes:

- Latency tracking.
- Error rate monitoring.
- Traffic analysis.

---

14. Logging & Monitoring

All important API activities must be logged.

Logs include:

- Request information.
- Authentication events.
- Errors.
- Performance metrics.

Sensitive information must never be stored in logs.

---

15. AI System API Standards

Aegis AI OS APIs must follow additional requirements:

- Secure model communication.
- Access-controlled document retrieval.
- Prompt validation.
- Response monitoring.
- Audit logging.

AI APIs must support:

- RAG pipelines.
- LLM integrations.
- Model evaluation.
- LangFuse tracing.

---

16. Deployment Requirements

Before production deployment:

Required approvals:

- Code review.
- Security approval.
- Testing completion.
- Deployment approval.

Deployment environments:

- Development.
- Testing.
- Staging.
- Production.

---

17. API Security Architecture

Aegis Bank follows a layered security architecture to protect API communication and banking services.

The API security model includes:

Client Application

↓

API Gateway

↓

Authentication Service

↓

Authorization Layer

↓

Business Logic Services

↓

Database Systems

API Gateway Security

All external API requests pass through the API Gateway.

Responsibilities:

- Request validation.
- Authentication verification.
- Rate limiting.
- Traffic monitoring.
- Threat detection.

---

18. API Governance Framework

Aegis Bank maintains API governance to ensure consistency and security.

Governance activities include:

- API approval process.
- Security review.
- Documentation verification.
- Lifecycle management.

- Performance monitoring.

API Lifecycle Management

Every API follows:

Planning

↓

Design

↓

Development

↓

Testing

↓

Security Review

↓

Production Deployment

↓

Monitoring

↓

Retirement

---

19. API Access Control Management

API access must follow the principle of least privilege.

Users and systems receive only required permissions.

Access Approval Process

1. Access request submitted.
2. Business justification reviewed.
3. Security validation performed.
4. Permission granted.
5. Access activity monitored.

---

20. API Data Protection Standards

Banking data transmitted through APIs must be protected.

Controls include:

- Encryption in transit.
- Encryption at rest.
- Data masking.
- Secure authentication.

- Access monitoring.

Sensitive Data Handling

Sensitive information includes:

- Customer identity data.
- Account numbers.
- Transaction information.
- Financial records.

Sensitive data must not:

- Appear in application logs.
- Be transmitted without encryption.
- Be shared with unauthorized systems.

---

21. API Change Management

All API changes must follow controlled processes.

Changes include:

- New endpoints.
- Database modifications.
- Authentication changes.
- Response format changes.

Change Process

Change Request

↓

Impact Analysis

↓

Developer Implementation

↓

Testing

↓

Security Approval

↓

Production Release

---

22. API Backup & Recovery Requirements

Critical APIs must support business continuity.

Requirements:

- Configuration backups.
- Database backups.
- Disaster recovery testing.
- Service restoration procedures.

Recovery Objectives

APIs must define:

Recovery Time Objective (RTO)

Maximum acceptable downtime.

Recovery Point Objective (RPO)

Maximum acceptable data loss.

---

23. AI API Workflow Standards

Aegis AI OS APIs support enterprise AI operations.

Example workflow:

Employee Question

↓

Authentication Check

↓

API Request Validation

↓

Document Retrieval Service

↓

Vector Database Search

↓

LLM Processing

↓

Response Evaluation

↓

Final Answer + Sources

↓

Logging & Monitoring

---

24. Banking API Practical Examples

Example 1 — Customer Account API

Request:

GET /api/v1/accounts/customer123

Process:

1. Verify customer identity.
2. Check permissions.

3. Retrieve account information.
4. Return encrypted response.

Example 2 — Loan Application API

Request:

POST /api/v1/loans/application

Validation:

- Customer identity.
- Income information.
- Credit score.
- Required documents.

Response:

Loan application status.

Example 3 — Payment Processing API

Process:

1. Authenticate request.
2. Validate transaction.
3. Check fraud rules.
4. Process payment.
5. Record transaction.

Example 4 — Aegis AI OS API

Employee asks:

"What is the loan approval policy?"

System:

1. Verify employee access.
2. Search approved documents.
3. Retrieve relevant policy.
4. Generate answer.
5. Show source reference.

---

25. API Monitoring & Alerting

Aegis Bank monitors API health continuously.

Monitoring metrics:

Metric	Purpose
Response Time	Measure performance
Error Rate	Detect failures
Traffic Volume	Analyze usage
Security Events	Detect threats
Availability	Ensure uptime

Alert Examples

Alerts are generated for:

- Failed authentication attempts.
- Unusual traffic patterns.
- API downtime.
- Security vulnerabilities.

---

26. API Documentation Example

Every API document should contain:

API Name

Customer Account API

Endpoint

GET /api/v1/accounts/{id}

Authentication

JWT Token Required

Request Parameters

Parameter	Type	Required
Customer ID	String	Yes

Response


```
{
 "accountStatus":"Active",
 "accountType":"Savings"
}
```


---

27. API Development Responsibilities

CTO

Responsible for:

- API strategy.
- Technology standards.
- Architecture approval.

Engineering Team

Responsible for:

- Secure coding.
- Testing.

- Documentation.
- Maintenance.

DevOps Team

Responsible for:

- Deployment.
- Monitoring.
- Infrastructure security.

Security Team

Responsible for:

- Security reviews.
- Vulnerability testing.
- Compliance validation.

---

28. Frequently Asked Questions (FAQs)

Q1. Why does Aegis Bank need API standards?

API standards ensure secure, reliable, and consistent communication between banking systems.

Q2. How are APIs protected?

Through authentication, authorization, encryption, monitoring, and security testing.

Q3. Can anyone access banking APIs?

No. API access requires proper authentication and authorization.

Q4. How does Aegis Bank secure AI APIs?

AI APIs use access controls, RAG security, monitoring, and audit logging.

Q5. How are API changes managed?

All changes require review, testing, approval, and controlled deployment.

Q6. What happens if an API fails?

Monitoring systems detect failures and recovery procedures are activated.

---

29. Related Documents

This document should be read with:

- AB-IT-002 — Database Standards
- AB-IT-003 — Docker Deployment Guide
- AB-IT-004 — CI/CD Standards
- AB-IT-005 — Logging & Monitoring Standards
- AB-SEC-003 — Cyber Security Policy
- AB-COMP-003 — Risk Management Framework

---

30. Revision History

Version	Date	Description	Author
v1.0	March 10, 2026	Initial API Development Standards Release	IT Engineering Department
v1.1	May 30, 2026	Added API Security and Governance Controls	Engineering Architecture Team
v1.2	**July 24, 2026**	**Enhanced API Security, AI Integration Standards, and Enterprise Governance Requirements**	**Information Technology Department**

---

31. Document Approval

Field	Details
Document ID	**AB-IT-001**
Document Title	**API Development Standards**
Department	Information Technology & Engineering
Version	**v1.2**
Classification	**Internal**
Document Owner	Chief Technology Officer (CTO)
Approved By	**Sami Khan – Chief Executive Officer (CEO)**
Approval Date	**July 24, 2026**
Next Review Date	**July 24, 2027**

Document Control

Attribute	Value
Document Status	Approved
Distribution	IT, Engineering, DevOps, Security, Architecture Teams
Language	English
Storage Location	Aegis Bank Document Management System (DMS)
Retention Period	7 Years
Supersedes	API Development Standards v1.1

End of Document

Aegis Bank
Enterprise AI Decision & Knowledge Platform for Modern Banking

© 2026 Aegis Bank. All Rights Reserved.